

Under the FedRAMP Moderate baseline, SR-5 (SR-5 Acquisition Strategies, Tools, and Methods):
FedRAMP Moderate Baseline · SR-5 · Acquisition Strategies, Tools, and Methods Control Statement:
Employ the following acquisition strategies, contract tools, and procurement methods to protect
against, identify, and mitigate supply chain risks: [organization-defined parameter]. Supplemental
Guidance: Employ the following acquisition strategies, contract tools, and procurement methods to
protect against, identify, and mitigate supply chain risks: [organization-defined parameter]. The
use of the

Control SR-9(1): SR-10 Policy and Procedures Supply Chain Risk Management Plan ESTABLISH SCRM TEAM
Supply Chain Controls and Processes DIVERSE SUPPLY BASE LIMITATION OF HARM SUB-TIER FLOW DOWN
Provenance IDENTITY TRACK AND TRACE VALIDATE AS GENUINE AND NOT ALTERED SUPPLY CHAIN INTEGRITY ·
PEDIGREE Acquisition Strategies, Tools, and Methods ADEQUATE SUPPLY ASSESSMENTS PRIOR TO SELECTION,
ACCEPTANCE, MODIFICATION, OR UPDATE Supplier Assessments and Reviews TESTING AND ANALYSIS Supply
Chain Operations Security Notification Agreements Tamper Resistance and Detection MULTIPLE STAGES OF
SYSTEM DEVELOPMENT LIFE CYCLE Inspection of Systems or Components

and c. Protect the supply chain risk management plan from unauthorized disclosure and modification.
Discussion: The dependence on products, systems, and services from external providers, as well as
the nature of the relationships with those providers, present an increasing level of risk to an
organization. Threat actions that may increase security or privacy risks include unauthorized
production, the insertion or use of counterfeits, tampering, theft, insertion of malicious software
and hardware, and poor manufacturing and development practices in the supply chain. Supply chain
risks can be endemic or systemic within a system element or component, a system, an organization, a
sector, or the Nation. Managing supply chain risk is a complex, multifaceted undertaking that
requires a coordinated effort across an organization to build trust relationships and communicate
with internal and external stakeholders. Supply chain risk management (SCRM) activities include
identifying and assessing risks, determining appropriate risk response actions, developing SCRM
plans to document response actions, and monitoring performance against plans. The SCRM plan (at the
system-level) is implementation specific, providing policy implementation, requirements, constraints
and implications. It can either be stand-alone, or incorporated into system security and privacy
plans.

NIST SP 800-53 Rev 5 control SR-12 (Component Disposal) is assessed by examining, interviewing, and
testing: SR-12 · Component Disposal Control Statement: Dispose of [organization-defined parameter]
using the following techniques and methods: [organization-defined parameter]. Supplemental
Guidance: Dispose of [organization-defined parameter] using the following techniques and methods:
[organization-defined parameter]. Data, documentation, tools, or system components can be disposed
of at any time during the system development life cycle (not only in the disposal or retirement
phase of the life cycle)

Under the FedRAMP Low baseline, SR-2 (SR-2 Supply Chain Risk Management Plan): FedRAMP Low Baseline
· SR-2 · Supply Chain Risk Management Plan Control Statement: a. Develop a plan for managing supply
chain risks associated with the research and development, design, manufacturing, acquisition,
delivery, integration, operations and maintenance, and disposal of the following systems, system
components or system services: [organization-defined parameter]; b. Review and update the supply
chain risk management plan [organization-defined parameter] or as required, to address thr

Under the FedRAMP High baseline, SR-2.1 (SR-2.1 Establish SCRM Team): FedRAMP High Baseline ·
SR-2.1 · Establish SCRM Team Control Statement: Establish a supply chain risk management team
consisting of [organization-defined parameter] to lead and support the following SCRM activities:
[organization-defined parameter]. Supplemental Guidance: Establish a supply chain risk management
team consisting of [organization-defined parameter] to lead and support the following SCRM
activities: [organization-defined parameter]. To implement supply chain risk management plans

NIST SP 800-53 Rev 5 control SR-3.1 (Diverse Supply Base) summarizes the requirements for this
control: SR-3.1 · Diverse Supply Base Control Statement: Employ a diverse set of sources for the
following system components and services: [organization-defined parameter]. Supplemental Guidance:
Employ a diverse set of sources for the following system components and services: [organization-
defined parameter]. Diversifying the supply of systems, system components, and services can reduce
the probability that adversaries will successfully identify and target the supply chain and can

reduce the impact of

Under the FedRAMP High baseline, SR-11.1 (SR-11.1 Anti-counterfeit Training): FedRAMP High Baseline · SR-11.1 · Anti-counterfeit Training Control Statement: Train [organization-defined parameter] to detect counterfeit system components (including hardware, software, and firmware). Supplemental Guidance: Train [organization-defined parameter] to detect counterfeit system components (including hardware, software, and firmware). None. Assessment Objectives: Train [organization-defined parameter] to detect counterfeit system components (including hardware, software, and fi

Under the FedRAMP Low baseline, SR-12 (SR-12 Component Disposal): FedRAMP Low Baseline · SR-12 · Component Disposal Control Statement: Dispose of [organization-defined parameter] using the following techniques and methods: [organization-defined parameter]. Supplemental Guidance: Dispose of [organization-defined parameter] using the following techniques and methods: [organization-defined parameter]. Data, documentation, tools, or system components can be disposed of at any time during the system development life cycle (not only in the disposal or retirement p

SR-4.4 · Supply Chain Integrity · Pedigree Control Statement: Employ [organization-defined parameter] and conduct [organization-defined parameter] to ensure the integrity of the system and system components by validating the internal composition and provenance of critical or mission-essential technologies, products, and services. Supplemental Guidance: Employ [organization-defined parameter] and conduct [organization-defined parameter] to ensure the integrity of the system and system components by validating the internal composition and provenance of critical or mission-essential technologies, products, and services. Authoritative information regarding the internal composition of system components and the provenance of technology, products, and services provides a strong basis for trust. The validation of the internal composition and provenance of technologies, products, and services is referred to as the pedigree. For microelectronics, this includes material composition of components. For software this includes the composition of open-source and proprietary code, including the version of the component at a given point in time. Pedigrees increase the assurance that the claims suppliers assert about the internal composition and provenance of the products, services, and technologies they provide are valid. The validation of the internal composition and provenance can be achieved by various evidentiary artifacts or records that manufacturers and suppliers produce during the research and development, design, manufacturing, acquisition, delivery, integration, operations and maintenance, and disposal of technology, products, and services. Evidentiary artifacts include, but are not limited to, software identification (SWID) tags, software component inventory, the manufacturers' declarations of platform attributes (e.g., serial numbers, hardware component inventory), and measurements (e.g., firmware hashes) that are tightly bound to the hardware itself.

prevent] physical tampering or alteration of [Assignment: organization- defined hardware components] within the system. Discussion: Organizations can implement tamper detection and prevention at selected hardware components or implement tamper detection at some components and tamper prevention at other components. Detection and prevention activities can employ many types of anti-tamper technologies, including tamper-detection seals and anti-tamper coatings. Anti-tamper programs help to detect hardware alterations through counterfeiting and other supply chain-related risks. Related Controls: SA-16, SR-9, SR-11. (6) PHYSICAL ACCESS CONTROL | FACILITY PENETRATION TESTING [Withdrawn: Incorporated into CA-8.] (7) PHYSICAL ACCESS CONTROL | PHYSICAL BARRIERS Limit access using physical barriers. Discussion: Physical barriers include bollards, concrete slabs, jersey walls, and hydraulic active vehicle barriers. Related Controls: None. (8) PHYSICAL ACCESS CONTROL | ACCESS CONTROL VESTIBULES Employ access control vestibules at [Assignment: organization-defined locations within the facility]. CHAPTER THREE PAGE 182 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5>. | NIST SP 800-53, REV.

NIST SP 800-171 Rev 3 control 03.17.02 (03.17.02 Acquisition Strategies, Tools, and Methods) is assessed by examining the following: Assessment Objectives: - acquisition strategies, contract tools, and procurement methods are developed to identify supply chain risks. - acquisition strategies, contract tools, and procurement methods are developed to protect against supply chain risks. - acquisition strategies, contract tools, and procurement methods are developed to mitigate supply chain risks. - acquisition strategies, contract tools, and procurement methods are implemented to identify supply chain risks. - acquisition strategies, contract tools, and

procurement methods are implemented to protect against supply chain risks.

NIST SP 800-53 Rev 5 control SR-11.2 (Configuration Control for Component Service and Repair) is assessed by examining, interviewing, and testing: SR-11.2 · Configuration Control for Component Service and Repair Control Statement: Maintain configuration control over the following system components awaiting service or repair and serviced or repaired components awaiting return to service: [organization-defined parameter]. Supplemental Guidance: Maintain configuration control over the following system components awaiting service or repair and serviced or repaired components awaiting return to service: [organization-defined parameter]. None.

NIST SP 800-171 Rev 3 control 03.17.01 (03.17.01 Supply Chain Risk Management Plan) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Supply Chain Risk Management (SR) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

and b. Maintain records of the system components. Discussion: Enforcing authorizations for entry and exit of system components may require restricting access to delivery areas and isolating the areas from the system and media libraries. Related Controls: CM-3, CM-8, MA-2, MA-3, MP-5, PE-20, SR-2, SR-3, SR-4, SR-6. CHAPTER THREE PAGE 190 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5>

5. | NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

Control Enhancements: None. References: None.

Under the FedRAMP Low baseline, SR-11.1 (SR-11.1 Anti-counterfeit Training): FedRAMP Low Baseline · SR-11.1 · Anti-counterfeit Training Control Statement: Train [organization-defined parameter] to detect counterfeit system components (including hardware, software, and firmware). Supplemental Guidance: Train [organization-defined parameter] to detect counterfeit system components (including hardware, software, and firmware). None. Assessment Objectives: Train [organization-defined parameter] to detect counterfeit system components (including hardware, software, and fir

NIST SP 800-53 Rev 5 control SR-5.1 (Adequate Supply) summarizes the requirements for this control: SR-5.1 · Adequate Supply Control Statement: Employ the following controls to ensure an adequate supply of [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Employ the following controls to ensure an adequate supply of [organization-defined parameter]: [organization-defined parameter]. Adversaries can attempt to impede organizational operations by disrupting the supply of critical system components or corrupting supplier operations. Organizations may tra

Under the FedRAMP Low baseline, SR-8 (SR-8 Notification Agreements): FedRAMP Low Baseline · SR-8 · Notification Agreements Control Statement: Establish agreements and procedures with entities involved in the supply chain for the system, system component, or system service for the [organization-defined parameter]. Supplemental Guidance: Establish agreements and procedures with entities involved in the supply chain for the system, system component, or system service for the [organization-defined parameter]. The establishment of agreements and procedures facilitat

and is responsible for ensuring agency compliance with, and prompt, efficient, and effective implementation of, the information policies and information resources management responsibilities, including the reduction of information collection burdens on the public. chief information security officer classified information classified national security information [EO 13526] See senior agency information security officer. See classified national security information. Information that has been determined pursuant to Executive Order (E.O.) 13526 or any predecessor order to require protection against unauthorized disclosure and is marked to indicate its classified status when in documentary form.

NIST SP 800-53 Rev 5 control SR-5.1 (Adequate Supply) is assessed by examining, interviewing, and testing: SR-5.1 · Adequate Supply Control Statement: Employ the following controls to ensure an adequate supply of [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Employ the following controls to ensure an adequate supply of [organization-defined

parameter]: [organization-defined parameter]. Adversaries can attempt to impede organizational operations by disrupting the supply of critical system components or corrupting supplier operations. Organizations may tra

NIST SP 800-53 Rev 5 control SR-8 (Notification Agreements) is assessed by examining, interviewing, and testing: SR-8 · Notification Agreements Control Statement: Establish agreements and procedures with entities involved in the supply chain for the system, system component, or system service for the [organization-defined parameter]. Supplemental Guidance: Establish agreements and procedures with entities involved in the supply chain for the system, system component, or system service for the [organization-defined parameter]. The establishment of agreements and procedures facilitates communications among

Under the FedRAMP Low baseline, SR-2.1 (SR-2.1 Establish SCRM Team): FedRAMP Low Baseline · SR-2.1 · Establish SCRM Team Control Statement: Establish a supply chain risk management team consisting of [organization-defined parameter] to lead and support the following SCRM activities: [organization-defined parameter]. Supplemental Guidance: Establish a supply chain risk management team consisting of [organization-defined parameter] to lead and support the following SCRM activities: [organization-defined parameter]. To implement supply chain risk management plans,

NIST SP 800-53 Rev 5 control SR-4 (Provenance) summarizes the requirements for this control: SR-4 · Provenance Control Statement: Document, monitor, and maintain valid provenance of the following systems, system components, and associated data: [organization-defined parameter]. Supplemental Guidance: Document, monitor, and maintain valid provenance of the following systems, system components, and associated data: [organization-defined parameter]. Every system and system component has a point of origin and may be changed throughout its existence. Provenance is the chronology of the ori

NIST SP 800-171 Rev 3 control 03.17.03 (03.17.03 Supply Chain Requirements and Processes) is assessed by examining the following: Assessment Objectives: - a process for identifying weaknesses or deficiencies in the supply chain elements and processes is established. - a process for addressing weaknesses or deficiencies in the supply chain elements and processes is established. - the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of supply chain-related events: [organization-defined parameter].

NIST SP 800-53 Rev 5 control SR-10 (Inspection of Systems or Components) summarizes the requirements for this control: SR-10 · Inspection of Systems or Components Control Statement: Inspect the following systems or system components [organization-defined parameter] to detect tampering: [organization-defined parameter]. Supplemental Guidance: Inspect the following systems or system components [organization-defined parameter] to detect tampering: [organization-defined parameter]. The inspection of systems or systems components for tamper resistance and detection addresses physical and logical tampering and is ap

Under the FedRAMP Low baseline, SR-3 (SR-3 Supply Chain Controls and Processes): FedRAMP Low Baseline · SR-3 · Supply Chain Controls and Processes Control Statement: a. Establish a process or processes to identify and address weaknesses or deficiencies in the supply chain elements and processes of [organization-defined parameter] in coordination with [organization-defined parameter]; b. Employ the following controls to protect against supply chain risks to the system, system component, or system service and to limit the harm or consequences from supply chain-related events:

NIST SP 800-171 Rev 3 control 03.17.01 (03.17.01 Supply Chain Risk Management Plan) is assessed by examining the following: Assessment Objectives: - a plan for managing supply chain risks is developed. - the SCRM plan addresses risks associated with the research and development of the system, system components, or system services. - the SCRM plan addresses risks associated with the design of the system, system components, or system services. - the SCRM plan addresses risks associated with the manufacturing of the system, system components, or system services. - the SCRM plan addresses risks associated with the acquisition of the system, system components, or system services. - the SCRM plan addresses risks associat

NIST SP 800-53 Rev 5 control SR-4.2 (Track and Trace) summarizes the requirements for this control:

SR-4.2 · Track and Trace Control Statement: Establish and maintain unique identification of the following systems and critical system components for tracking through the supply chain: [organization-defined parameter]. Supplemental Guidance: Establish and maintain unique identification of the following systems and critical system components for tracking through the supply chain: [organization-defined parameter]. Tracking the unique identification of systems and system components during developm

Under the FedRAMP High baseline, SR-6 (SR-6 Supplier Assessments and Reviews): FedRAMP High Baseline · SR-6 · Supplier Assessments and Reviews Control Statement: Assess and review the supply chain-related risks associated with suppliers or contractors and the system, system component, or system service they provide [organization-defined parameter]. Supplemental Guidance: Assess and review the supply chain-related risks associated with suppliers or contractors and the system, system component, or system service they provide [organization-defined parameter]. An assessment

Related Controls: SR-02 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.17.01.b [Assignment: organization- defined frequency] at least every 12 months, or when there are significant1 incidents or significant1 changes to risks Supply Chain Risk Management 3.17.3 Supply Chain Security Requirements a. Establish a process for identifying and addressing weaknesses or deficiencies in the supply chain elements and processes. b. Enforce the following security requirements to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences from supply chain- related events: [Assignment: organization-defined security requirements] (03.17.03.b). Related Controls: SR-03 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.17.03.b [Assignment: organization- defined security requirements] at a minimum, integrate Supply Chain Risk Management (SCRM) into acquisition/procurement policies, provide adequate SCRM resources, define the SCRM control baseline, establish processes to ensure suppliers disclose significant1 vulnerabilities and significant1 incidents

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY 2555 DLO ADVERSARY EFFECTS Expose (Detect) REFERENCES Source Control: SR-10 03.17.03 E Co mponent Authenticity a. Develop and implement anti-counterfeit policy and procedures that include the means to detect and prevent counterfeit components from entering the system. b. Report counterfeit system components to [Selection (one or more): source of counterfeit component; [Assignment: organization-defined external reporting organizations]; [Assignment: organization-defined personnel or roles]]. DISCUSSION Sources of counterfeit components include manufacturers, developers, vendors, and contractors. Anti-counterfeiting policies and procedures support tamper resistance and provide a level of protection against the introduction of malicious code. External repo

NIST SP 800-171 Rev 3 control 03.17.02 (03.17.02 Acquisition Strategies, Tools, and Methods) falls under the Supply Chain Risk Management family. 03.17.02 · Acquisition Strategies, Tools, and Methods Supplemental Guidance: The acquisition process provides an important vehicle for protecting the supply chain. There are many useful tools and techniques available, including obscuring the end use of a system or system component, using blind purchases, requiring tamperevident packaging, or using trusted or controlled distribution. The results from a supply chain risk assessment can inform the strategies, tools, and methods that are most appli Supplemental Guidance: The acquisition process provides an important vehicle for protecting the supply chain. There are many useful tools and techniques available, including obscuring the end use of a system or system component, using blind purchases, requiring tamperevident packaging, or using trusted or controlled distribution. The results from a supply chain risk assessment can inform the strategies, tools, and methods that are most applicable to the situation. Tools and techniques may provid

NIST SP 800-53 Rev 5 control SR-3.2 (Limitation of Harm) summarizes the requirements for this control: SR-3.2 · Limitation of Harm Control Statement: Employ the following controls to limit harm from potential adversaries identifying and targeting the organizational supply chain: [organization-defined parameter]. Supplemental Guidance: Employ the following controls to limit harm from potential adversaries identifying and targeting the organizational supply chain: [organization-defined parameter]. Controls that can be implemented to reduce the probability of adversaries successfully identifying a

Under the FedRAMP High baseline, SR-9.1 (SR-9.1 Multiple Stages of System Development Life Cycle):

FedRAMP High Baseline · SR-9.1 · Multiple Stages of System Development Life Cycle Control Statement: Employ anti-tamper technologies, tools, and techniques throughout the system development life cycle. Supplemental Guidance: Employ anti-tamper technologies, tools, and techniques throughout the system development life cycle. The system development life cycle includes research and development, design, manufacturing, acquisition, delivery, integration, operations and maintenance, and disposal. Or

NIST SP 800-171 Rev 3 control 03.17.03 (03.17.03 Supply Chain Requirements and Processes) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Supply Chain Risk Management (SR) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control SR-6.1 (Testing and Analysis) is defined as follows: SR-6.1 · Testing and Analysis Control Statement: Employ [organization-defined parameter] of the following supply chain elements, processes, and actors associated with the system, system component, or system service: [organization-defined parameter]. Supplemental Guidance: Employ [organization-defined parameter] of the following supply chain elements, processes, and actors associated with the system, system component, or system service: [organization-defined parameter]. Relationships between entities and procedures within the supply chain, including development and delivery, are considered. S

NIST SP 800-53 Rev 5 control SR-3.3 (Sub-tier Flow Down) summarizes the requirements for this control: SR-3.3 · Sub-tier Flow Down Control Statement: Ensure that the controls included in the contracts of prime contractors are also included in the contracts of subcontractors. Supplemental Guidance: Ensure that the controls included in the contracts of prime contractors are also included in the contracts of subcontractors. To manage supply chain risk effectively and holistically, it is important that organizations ensure that supply chain risk management controls are included at all tiers in the

Control SR-11: -defined frequency]. Discussion: The type of component determines the type of scanning to be conducted (e.g., web application scanning if the component is a web application). Related Controls: RA-5. CHAPTER THREE PAGE 372 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5>. NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

References: [ISO 20243].

NIST SP 800-53 Rev 5 control SR-11 (Component Authenticity) is defined as follows: SR-11 · Component Authenticity Control Statement: a. Develop and implement anti-counterfeit policy and procedures that include the means to detect and prevent counterfeit components from entering the system; and b. Report counterfeit system components to [organization-defined parameter]. Supplemental Guidance: a. Develop and implement anti-counterfeit policy and procedures that include the means to detect and prevent counterfeit components from entering the system; and b. Report counterfeit system components to [organization-defined parameter]. Sources of counterfeit components include manuf

Under the FedRAMP Moderate baseline, SR-11.1 (SR-11.1 Anti-counterfeit Training): FedRAMP Moderate Baseline · SR-11.1 · Anti-counterfeit Training Control Statement: Train [organization-defined parameter] to detect counterfeit system components (including hardware, software, and firmware). Supplemental Guidance: Train [organization-defined parameter] to detect counterfeit system components (including hardware, software, and firmware). None. Assessment Objectives: Train [organization-defined parameter] to detect counterfeit system components (including hardware, software, an

NIST SP 800-53 Rev 5 control SR-3 (Supply Chain Controls and Processes): SR-3 · Supply Chain Controls and Processes Control Statement: a. Establish a process or processes to identify and address weaknesses or deficiencies in the supply chain elements and processes of [organization-defined parameter] in coordination with [organization-defined parameter]; b. Employ the following

controls to protect against supply chain risks to the system, system component, or system service

NIST SP 800-53 Rev 5 control SR-12 (Component Disposal) summarizes the requirements for this control: SR-12 · Component Disposal Control Statement: Dispose of [organization-defined parameter] using the following techniques and methods: [organization-defined parameter]. Supplemental Guidance: Dispose of [organization-defined parameter] using the following techniques and methods: [organization-defined parameter]. Data, documentation, tools, or system components can be disposed of at any time during the system development life cycle (not only in the disposal or retirement phase of the life cycle)

NIST SP 800-171 Rev 3 control 03.17.02 (03.17.02 Acquisition Strategies, Tools, and Methods) is assessed by examining the following: Assessment Objectives: - acquisition strategies, contract tools, and procurement methods are developed to identify supply chain risks. - acquisition strategies, contract tools, and procurement methods are developed to protect against supply chain risks. - acquisition strategies, contract tools, and procurement methods are developed to mitigate supply chain risks. - acquisition strategies, contract tools, and procurement methods are implemented to identify supply chain risks. - acquisition strategies, contract tools, and procurement methods are implemented to protect against supply chain risks.

Under the FedRAMP Moderate baseline, SR-12 (SR-12 Component Disposal): FedRAMP Moderate Baseline · SR-12 · Component Disposal Control Statement: Dispose of [organization-defined parameter] using the following techniques and methods: [organization-defined parameter]. Supplemental Guidance: Dispose of [organization-defined parameter] using the following techniques and methods: [organization-defined parameter]. Data, documentation, tools, or system components can be disposed of at any time during the system development life cycle (not only in the disposal or retirement phase of the life cycle)

NIST SP 800-53 Rev 5 control SR-4.3 (Validate as Genuine and Not Altered) is assessed by examining, interviewing, and testing: SR-4.3 · Validate as Genuine and Not Altered Control Statement: Employ the following controls to validate that the system or system component received is genuine and has not been altered: [organization-defined parameter]. Supplemental Guidance: Employ the following controls to validate that the system or system component received is genuine and has not been altered: [organization-defined parameter]. For many systems and system components, especially hardware, there are technical means to determine

SR-6 · Supplier Assessments and Reviews Control Statement: Assess and review the supply chain-related risks associated with suppliers or contractors and the system, system component, or system service they provide [organization-defined parameter]. Supplemental Guidance: Assess and review the supply chain-related risks associated with suppliers or contractors and the system, system component, or system service they provide [organization-defined parameter]. An assessment and review of supplier risk includes security and supply chain risk management processes, foreign ownership, control or influence (FOCI), and the ability of the supplier to effectively assess subordinate second-tier and third-tier suppliers and contractors. The reviews may be conducted by the organization or by an independent third party. The reviews consider documented processes, documented controls, all-source intelligence, and publicly available information related to the supplier or contractor. Organizations can use open-source information to monitor for indications of stolen information, poor development and quality control practices, information spillage, or counterfeits. In some cases, it may be appropriate or required to share assessment and review results with other organizations in accordance with any applicable rules, policies, or inter-organizational agreements or contracts.

Under the FedRAMP Low baseline, SR-10 (SR-10 Inspection of Systems or Components): FedRAMP Low Baseline · SR-10 · Inspection of Systems or Components Control Statement: Inspect the following systems or system components [organization-defined parameter] to detect tampering: [organization-defined parameter]. Supplemental Guidance: Inspect the following systems or system components [organization-defined parameter] to detect tampering: [organization-defined parameter]. The inspection of systems or system components for tamper resistance and detection addresses physical and log

NIST SP 800-53 Rev 5 control SR-2.1 (Establish SCRM Team) summarizes the requirements for this control: SR-2.1 · Establish SCRM Team Control Statement: Establish a supply chain risk management

team consisting of [organization-defined parameter] to lead and support the following SCRM activities: [organization-defined parameter]. Supplemental Guidance: Establish a supply chain risk management team consisting of [organization-defined parameter] to lead and support the following SCRM activities: [organization-defined parameter]. To implement supply chain risk management plans, organizations establish

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Related Controls: SR-02 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.17.01.b [Assignment: organization-defined frequency] at least every 12 months, or when there are significant incidents or significant changes to risks Supply Chain Risk Management 3.17.3 Supply Chain Security Requirements a. Establish a process for identifying and addressing weaknesses or deficiencies in the supply chain elements and processes. b. Enforce the following security requirements to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences from supply chain-related events: [Assignment: organization-defined security requirements] (03.17.03.b). Related Controls: SR-03 ODP Values ODP Identifier ODP Assignment T

Under the FedRAMP High baseline, SR-2 (SR-2 Supply Chain Risk Management Plan): FedRAMP High Baseline · SR-2 · Supply Chain Risk Management Plan Control Statement: a. Develop a plan for managing supply chain risks associated with the research and development, design, manufacturing, acquisition, delivery, integration, operations and maintenance, and disposal of the following systems, system components or system services: [organization-defined parameter]; b. Review and update the supply chain risk management plan [organization-defined parameter] or as required, to address th

NIST SP 800-53 Rev 5 control SR-7 (Supply Chain Operations Security) is assessed by examining, interviewing, and testing: SR-7 · Supply Chain Operations Security Control Statement: Employ the following Operations Security (OPSEC) controls to protect supply chain-related information for the system, system component, or system service: [organization-defined parameter]. Supplemental Guidance: Employ the following Operations Security (OPSEC) controls to protect supply chain-related information for the system, system component, or system service: [organization-defined parameter]. Supply chain OPSEC expands the scope o

From the NIST SP 800-172 Rev 3 Final Public Draft: Supply Chain Risk Management 03.17.01 E Notification Agreements NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 Establish agreements and procedures with entities involved in the supply chain for 2522

NIST SP 800-171 Rev 3 control 03.17.03 (03.17.03 Supply Chain Requirements and Processes) is assessed by examining the following: Assessment Objectives: - a process for identifying weaknesses or deficiencies in the supply chain elements and processes is established. - a process for addressing weaknesses or deficiencies in the supply chain elements and processes is established. - the following security requirements are enforced to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences of supply chain-related events: [organization-defined parameter].

NIST SP 800-53 Rev 5 control SR-4.3 (Validate as Genuine and Not Altered): SR-4.3 · Validate as Genuine and Not Altered Control Statement: Employ the following controls to validate that the system or system component received is genuine and has not been altered: [organization-defined parameter]. Supplemental Guidance: Employ the following controls to validate that the system or system component received is genuine and has not been altered: [organization-defined paramet

NIST SP 800-171 Rev 3 control 03.17.02 (03.17.02 Acquisition Strategies, Tools, and Methods) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Supply Chain Risk Management (SR) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control SR-3 (Supply Chain Controls and Processes) summarizes the requirements for this control: SR-3 · Supply Chain Controls and Processes Control Statement: a. Establish a process or processes to identify and address weaknesses or deficiencies in the supply chain elements

and processes of [organization-defined parameter] in coordination with [organization-defined parameter]; b. Employ the following controls to protect against supply chain risks to the system, system component, or system service and to limit the harm or consequences from supply chain-related events: [organization-defined

2 External Service Providers (ESP): External people, technology, or facilities that an organization utilizes for provision and management of IT and/or cybersecurity services on behalf of the organization . Supply Chain Risk Management 3.17.1 Supply Chain Risk Management Plan a. Develop a plan for managing supply chain risks associated with the research and development, design, manufacturing, acquisition, delivery, integration, operations, maintenance, and disposal of the system, system components, or system services. b. Review and update the supply chain risk management plan [Assignment: organization-defined frequency] (03.17.01.b). c. Protect the supply chain risk management plan from unauthorized disclosure. Related Controls: SR-02 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.17.01.b [Assignment: organization-defined frequency] at least every 12 months, or when there are significant incidents or significant changes to risks

NIST SP 800-53 Rev 5 control SR-6.1 (Testing and Analysis) is assessed by examining, interviewing, and testing: SR-6.1 · Testing and Analysis Control Statement: Employ [organization-defined parameter] of the following supply chain elements, processes, and actors associated with the system, system component, or system service: [organization-defined parameter]. Supplemental Guidance: Employ [organization-defined parameter] of the following supply chain elements, processes, and actors associated with the system, system component, or system service: [organization-defined parameter]. Relationships between en

NIST SP 800-53 Rev 5 control SR-7 (Supply Chain Operations Security) summarizes the requirements for this control: SR-7 · Supply Chain Operations Security Control Statement: Employ the following Operations Security (OPSEC) controls to protect supply chain-related information for the system, system component, or system service: [organization-defined parameter]. Supplemental Guidance: Employ the following Operations Security (OPSEC) controls to protect supply chain-related information for the system, system component, or system service: [organization-defined parameter]. Supply chain OPSEC expands the scope o

Establish agreements and procedures with entities involved in the supply chain for 2522 the system, system component, or system service for th e [Selection (one or more): notification of supply chain compromises; results of assessments or audits; [Assignment: organization-defined information]]. DI SCUSSION Establishing agreements and procedures facilitates communications among supply chain entities. Early notification of compromises and potential compromises in the supply chain that may adversely affect or have adversely affected organizational systems or system components is essential for organizations to effectively respond to such incidents. The results of assessments or audits may include open-source information that contributed to a decision or result and could be used to help the supply chain entity resolve a concern or improve its processes. This requirement is sourced to a control tailored out of the SP 800-53B [13] moderate baseline in SP 800-171. PROTECTION STRATEGY DLO ADVERSARY EFFECTS Expose (Detect), Limit (Shorten, Reduce) REFERENCES Source Control: SR-08 03.17.02 E Inspection of Systems or Components Inspect the following systems or system components [Selection (one or more): at random; [Assignment: organization-defined frequency]; upon [Assignment: organization-defined indications of need for inspection]] to detect tampering: [Assignment: organization-defined systems or system components]. DISCUSSION Inspecting systems or systems components for evidence of tampering addresses physical and logical tampering and is applied to systems and system components that are removed from organization-controlled areas. Indications of a need for inspection include changes in packaging, specifications, factory location, or entity in which the part is purchased, and when individuals return from travel to high-risk locations. This requirement is sourced to a control tailored out of the SP 800-53B [13] moderate baseline in SP 800-171.

NIST SP 800-53 Rev 5 control SR-2.1 (Establish SCRM Team) is assessed by examining, interviewing, and testing: SR-2.1 · Establish SCRM Team Control Statement: Establish a supply chain risk management team consisting of [organization-defined parameter] to lead and support the following SCRM activities: [organization-defined parameter]. Supplemental Guidance: Establish a supply chain risk management team consisting of [organization-defined parameter] to lead and support the

following SCRM activities: [organization-defined parameter]. To implement supply chain risk management plans, organizations establish

NIST SP 800-53 Rev 5 control SR-6.1 (Testing and Analysis) summarizes the requirements for this control: SR-6.1 · Testing and Analysis Control Statement: Employ [organization-defined parameter] of the following supply chain elements, processes, and actors associated with the system, system component, or system service: [organization-defined parameter]. Supplemental Guidance: Employ [organization-defined parameter] of the following supply chain elements, processes, and actors associated with the system, system component, or system service: [organization-defined parameter]. Relationships between en

Under the FedRAMP High baseline, SR-12 (SR-12 Component Disposal): FedRAMP High Baseline · SR-12 · Component Disposal Control Statement: Dispose of [organization-defined parameter] using the following techniques and methods: [organization-defined parameter]. Supplemental Guidance: Dispose of [organization-defined parameter] using the following techniques and methods: [organization-defined parameter]. Data, documentation, tools, or system components can be disposed of at any time during the system development life cycle (not only in the disposal or retirement

Under the FedRAMP Low baseline, SR-1 (SR-1 Policy and Procedures): FedRAMP Low Baseline · SR-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] supply chain risk management policy that: 2. Procedures to facilitate the implementation of the supply chain risk management policy and the associated supply chain risk management controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the supply

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 artifacts include software identification (SWID) tags, software component inventory, 2622 the manufacturers' declarations of platform attributes (e.g., serial numbers, hardware component inventory), and measurements (e.g., firmware hashes) that are tightly bound to the hardware. This requirement does not enhance a specific requirement in SP 800-171 but can be used to strengthen the protection of CUI associated with critical programs or high value assets. PROTECTION STRATEGY DLO ADVERSARY EFFECTS Expose (Detect) REFERENCES Source Control: SR-04(04) NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 References 2

Under the FedRAMP Moderate baseline, SR-1 (SR-1 Policy and Procedures): FedRAMP Moderate Baseline · SR-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] supply chain risk management policy that: 2. Procedures to facilitate the implementation of the supply chain risk management policy and the associated supply chain risk management controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the s

Under the FedRAMP High baseline, SR-10 (SR-10 Inspection of Systems or Components): FedRAMP High Baseline · SR-10 · Inspection of Systems or Components Control Statement: Inspect the following systems or system components [organization-defined parameter] to detect tampering: [organization-defined parameter]. Supplemental Guidance: Inspect the following systems or system components [organization-defined parameter] to detect tampering: [organization-defined parameter]. The inspection of systems or systems components for tamper resistance and detection addresses physical and log

Under the FedRAMP High baseline, SR-8 (SR-8 Notification Agreements): FedRAMP High Baseline · SR-8 · Notification Agreements Control Statement: Establish agreements and procedures with entities involved in the supply chain for the system, system component, or system service for the [organization-defined parameter]. Supplemental Guidance: Establish agreements and procedures with entities involved in the supply chain for the system, system component, or system service for the [organization-defined parameter]. The establishment of agreements and procedures facilita

NIST SP 800-53 Rev 5 control SR-3 (Supply Chain Controls and Processes) is assessed by examining, interviewing, and testing: SR-3 · Supply Chain Controls and Processes Control Statement: a. Establish a process or processes to identify and address weaknesses or deficiencies in the supply

chain elements and processes of [organization-defined parameter] in coordination with [organization-defined parameter]; b. Employ the following controls to protect against supply chain risks to the system, system component, or system service and to limit the harm or consequences from supply chain-related events: [organization-defined]

NIST SP 800-171 Rev 3 control 03.17.03 (03.17.03 Supply Chain Requirements and Processes) requires organizations to implement the following: Control Statement: SR-03.17.03.a Establish a process for identifying and addressing weaknesses or deficiencies in the supply chain elements and processes. SR-03.17.03.b Enforce the following security requirements to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences from supply chain-related events: [organization-defined parameter]. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.17.03.

Under the FedRAMP Low baseline, SR-11 (SR-11 Component Authenticity): FedRAMP Low Baseline · SR-11 · Component Authenticity Control Statement: a. Develop and implement anti-counterfeit policy and procedures that include the means to detect and prevent counterfeit components from entering the system; and b. Report counterfeit system components to [organization-defined parameter]. Supplemental Guidance: a. Develop and implement anti-counterfeit policy and procedures that include the means to detect and prevent counterfeit components from entering the system; and b

NIST SP 800-171 Rev 3 control 03.17.03 (03.17.03 Supply Chain Requirements and Processes) requires organizations to implement the following: Control Statement: SR-03.17.03.a Establish a process for identifying and addressing weaknesses or deficiencies in the supply chain elements and processes. SR-03.17.03.b Enforce the following security requirements to protect against supply chain risks to the system, system components, or system services and to limit the harm or consequences from supply chain-related events: [organization-defined parameter]. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.17.03.

NIST SP 800-171 Rev 3 control 03.17.01 (03.17.01 Supply Chain Risk Management Plan) is assessed by examining the following: Assessment Objectives: - a plan for managing supply chain risks is developed. - the SCRM plan addresses risks associated with the research and development of the system, system components, or system services. - the SCRM plan addresses risks associated with the design of the system, system components, or system services. - the SCRM plan addresses risks associated with the manufacturing of the system, system components, or system services. - the SCRM plan addresses risks associated with the acquisition of the system, system components, or system services. - the SCRM plan addresses risks associat

NIST SP 800-53 Rev 5 control SR-4 (Provenance) is defined as follows: SR-4 · Provenance Control Statement: Document, monitor, and maintain valid provenance of the following systems, system components, and associated data: [organization-defined parameter]. Supplemental Guidance: Document, monitor, and maintain valid provenance of the following systems, system components, and associated data: [organization-defined parameter]. Every system and system component has a point of origin and may be changed throughout its existence. Provenance is the chronology of the origin, development, ownership, location, and changes to a system or system component and associated da

SR-3.2 · Limitation of Harm Control Statement: Employ the following controls to limit harm from potential adversaries identifying and targeting the organizational supply chain: [organization-defined parameter]. Supplemental Guidance: Employ the following controls to limit harm from potential adversaries identifying and targeting the organizational supply chain: [organization-defined parameter]. Controls that can be implemented to reduce the probability of adversaries successfully identifying and targeting the supply chain include avoiding the purchase of custom or non-standardized configurations, employing approved vendor lists with standing reputations in industry, following pre-agreed maintenance schedules and update and patch delivery mechanisms, maintaining a contingency plan in case of a supply chain event, using procurement carve-outs that provide exclusions to commitments or obligations, using diverse delivery routes, and minimizing the time between purchase decisions and delivery.

NIST SP 800-53 Rev 5 control SR-11.1 (Anti-counterfeit Training) summarizes the requirements for

this control: SR-11.1 · Anti-counterfeit Training Control Statement: Train [organization-defined parameter] to detect counterfeit system components (including hardware, software, and firmware). Supplemental Guidance: Train [organization-defined parameter] to detect counterfeit system components (including hardware, software, and firmware). None.

NIST SP 800-171 Rev 3 control 03.17.02 (03.17.02 Acquisition Strategies, Tools, and Methods) requires organizations to implement the following: 03.17.02 · Acquisition Strategies, Tools, and Methods Supplemental Guidance: The acquisition process provides an important vehicle for protecting the supply chain. There are many useful tools and techniques available, including obscuring the end use of a system or system component, using blind purchases, requiring tamperevident packaging, or using trusted or controlled distribution. The results from a supply chain risk assessment can inform the strategies, tools, and methods that are most appli For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.17.02.

SR-7 · Supply Chain Operations Security Control Statement: Employ the following Operations Security (OPSEC) controls to protect supply chain-related information for the system, system component, or system service: [organization-defined parameter]. Supplemental Guidance: Employ the following Operations Security (OPSEC) controls to protect supply chain-related information for the system, system component, or system service: [organization-defined parameter]. Supply chain OPSEC expands the scope of OPSEC to include suppliers and potential suppliers. OPSEC is a process that includes identifying critical information, analyzing friendly actions related to operations and other activities to identify actions that can be observed by potential adversaries, determining indicators that potential adversaries might obtain that could be interpreted or pieced together to derive information in sufficient time to cause harm to organizations, implementing safeguards or countermeasures to eliminate or reduce exploitable vulnerabilities and risk to an acceptable level, and considering how aggregated information may expose users or specific uses of the supply chain. Supply chain information includes user identities; uses for systems, system components, and system services; supplier identities; security and privacy requirements; system and component configurations; supplier processes; design specifications; and testing and evaluation results. Supply chain OPSEC may require organizations to withhold mission or business information from suppliers and may include the use of intermediaries to hide the end use or users of systems, system components, or system services.

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: 2 External Service Providers (ESP): External people, technology, or facilities that an organization utilizes for provision and management of IT and/or cybersecurity services on behalf of the organization . Supply Chain Risk Management 3.17.1 Supply Chain Risk Management Plan a. Develop a plan for managing supply chain risks associated with the research and development, design, manufacturing, acquisition, delivery, integration, operations, maintenance, and disposal of the system, system components, or system services. b. Review and update the supply chain risk management plan [Assignment: organization-defined frequency] (03.17.01.b). c. Protect the supply chain risk management plan from unauthorized disclosure. Related Controls: SR-02 ODP Values ODP Identifier ODP Assignment Te

NIST SP 800-53 Rev 5 control SR-4.4 (Supply Chain Integrity · Pedigree) summarizes the requirements for this control: SR-4.4 · Supply Chain Integrity · Pedigree Control Statement: Employ [organization-defined parameter] and conduct [organization-defined parameter] to ensure the integrity of the system and system components by validating the internal composition and provenance of critical or mission-essential technologies, products, and services. Supplemental Guidance: Employ [organization-defined parameter] and conduct [organization-defined parameter] to ensure the integrity of the system and system component

NIST SP 800-53 Rev 5 control SR-9.1 (Multiple Stages of System Development Life Cycle) summarizes the requirements for this control: SR-9.1 · Multiple Stages of System Development Life Cycle Control Statement: Employ anti-tamper technologies, tools, and techniques throughout the system development life cycle. Supplemental Guidance: Employ anti-tamper technologies, tools, and techniques throughout the system development life cycle. The system development life cycle includes research and development, design, manufacturing, acquisition, delivery, integration, operations and maintenance, and disposal. Organizations use a combin

NIST SP 800-53 Rev 5 control SR-4.1 (Identity) summarizes the requirements for this control: SR-4.1 · Identity Control Statement: Establish and maintain unique identification of the following supply chain elements, processes, and personnel associated with the identified system and critical system components: [organization-defined parameter]. Supplemental Guidance: Establish and maintain unique identification of the following supply chain elements, processes, and personnel associated with the identified system and critical system components: [organization-defined parameter]. Knowing wh

Control SR-1: rd to revoke a user's access once a JWT is issued. Community standards, such as Internet Engineering Task Force (IETF) Request for Comments (RFC) for OAuth2 Introspection, can be used to address this. An example of an authorization policy that will enable the sidecar itself to make an access control decision based on claims in the JWT and enforce it, without calling on an external authorization system, is given below: apiVersion: security.istio.io/v1beta1 kind: AuthorizationPolicy metadata: name: backend namespace: product spec: action: ALLOW rules: - from: - source: principals: ["cluster.local/ns/product/sa/frontend"] to: - operation: methods: ["GET"] paths: ["/info*"] - operation: methods: ["POST"] paths: ["/data"] when: - key: request.auth.claims[iss] values: ["accounts.google.com"] Figure 4.1 - An example Istio authorization policy This allows the front end to call specific methods on the backend only if the request has an EUC attached issued by 'accounts.google.com.' EUAZ-SR-3 : All application traffic should carry end user credentials, and there should be a policy in the mesh enforcing that credentials are present. This is recommended even if the application is enforcing authentication and authorization independently of the mesh because these organization-wide controls allow functionalities like audit to be built on top of the mesh at a lower cost to central teams responsible for compliance and controls. ## 4.5.3 Model-based Authorization Policies The service-level authorization policies and a use case of end-user authorization policies that uses JWT are natively implemented in the proxies. Since these cannot be used for resourcelevel authorization policies, support for model-based authorization policies is needed as well. As already alluded to in Section 4.5.2, this requires a call from the proxy to an external authorization server, which holds the model-based authorization engine to obtain an access decision.

Under the FedRAMP High baseline, SR-1 (SR-1 Policy and Procedures): FedRAMP High Baseline · SR-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] supply chain risk management policy that: 2. Procedures to facilitate the implementation of the supply chain risk management policy and the associated supply chain risk management controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the suppl

NIST SP 800-53 Rev 5 control SR-11 (Component Authenticity) is assessed by examining, interviewing, and testing: SR-11 · Component Authenticity Control Statement: a. Develop and implement anti-counterfeit policy and procedures that include the means to detect and prevent counterfeit components from entering the system; and b. Report counterfeit system components to [organization-defined parameter]. Supplemental Guidance: a. Develop and implement anti-counterfeit policy and procedures that include the means to detect and prevent counterfeit components from entering the system; and b. Report counterfeit sy

NIST SP 800-53 Rev 5 control SR-4.1 (Identity) is defined as follows: SR-4.1 · Identity Control Statement: Establish and maintain unique identification of the following supply chain elements, processes, and personnel associated with the identified system and critical system components: [organization-defined parameter]. Supplemental Guidance: Establish and maintain unique identification of the following supply chain elements, processes, and personnel associated with the identified system and critical system components: [organization-defined parameter]. Knowing who and what is in the supply chains of organizations is critical to gaining visibility into supply ch

Implementing 03.17.03 (03.17.03 Supply Chain Requirements and Processes) differs between cloud and on-premises environments in several ways: **On-premises**: The organization has direct control over all infrastructure components. Implementation of 03.17.03 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. **Cloud (IaaS/PaaS/SaaS)**: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the

service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.17.03 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

Implementing 03.17.02 (03.17.02 Acquisition Strategies, Tools, and Methods) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.17.02 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.17.02 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

Control SA-12: SUPPLY CHAIN PROTECTION [Withdrawn: Incorporated into SR Family.] Control Enhancements: (1) SUPPLY CHAIN PROTECTION | ACQUISITION STRATEGIES / TOOLS / METHODS [Withdrawn: Moved to SR-5.] (2) SUPPLY CHAIN PROTECTION | SUPPLIER REVIEWS [Withdrawn: Moved to SR-6.] (3) SUPPLY CHAIN PROTECTION | TRUSTED SHIPPING AND WAREHOUSING [Withdrawn: Incorporated into SR-3.] (4) SUPPLY CHAIN PROTECTION | DIVERSITY OF SUPPLIERS [Withdrawn: Moved to SR-3(1).] (5) SUPPLY CHAIN PROTECTION | LIMITATION OF HARM [Withdrawn: Moved to SR-3(2).] (6) SUPPLY CHAIN PROTECTION | MINIMIZING PROCUREMENT TIME [Withdrawn: Incorporated into SR-5(1).] (7) SUPPLY CHAIN PROTECTION | ASSESSMENTS PRIOR TO SELECTION / ACCEPTANCE / UPDATE [Withdrawn: Moved to SR-5(2).] (8) SUPPLY CHAIN PROTECTION | USE OF ALL-SOURCE INTELLIGENCE [Withdrawn: Incorporated into RA-3(2).] (9) SUPPLY CHAIN PROTECTION | OPERATIONS SECURITY [Withdrawn: Moved to SR-7.] (10) SUPPLY CHAIN PROTECTION | VALIDATE AS GENUINE AND NOT ALTERED [Withdrawn: Moved to SR-4(3).] (11) SUPPLY CHAIN PROTECTION | PENETRATION TESTING / ANALYSIS OF ELEMENTS, PROCESSES, AND ACTORS [Withdrawn: Moved to SR-6(1).] (12) SUPPLY CHAIN PROTECTION | INTER-ORGANIZATIONAL AGREEMENTS [Withdrawn: Moved to SR-8.] (13) SUPPLY CHAIN PROTECTION | CRITICAL INFORMATION SYSTEM COMPONENTS [Withdrawn: Incorporated into MA-6 and RA-9.] (14) SUPPLY CHAIN PROTECTION | IDENTITY AND TRACEABILITY [Withdrawn: Moved to SR-4(1) and SR-4(2).] (15) SUPPLY CHAIN PROTECTION | PROCESSES TO ADDRESS WEAKNESSES OR DEFICIENCIES [Withdrawn: Incorporated into SR-3.]

Control SR-6: SUPPLIER ASSESSMENTS AND REVIEWS Control: Assess and review the supply chain-related risks associated with suppliers or contractors and the system, system component, or system service they provide [Assignment: organization-defined frequency]. CHAPTER THREE PAGE 369 T h s i p u b l i c a t i o n i s a v a i l a b e f r e e o f c h a r g e f r o m : <https://doi.org/10.6028/NIST.SP.800-53r5>. I NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

Discussion: An assessment and review of supplier risk includes security and supply chain risk management processes, foreign ownership, control or influence (FOCI), and the ability of the supplier to effectively assess subordinate second-tier and third-tier suppliers and contractors. The reviews may be conducted by the organization or by an independent third party. The reviews consider documented processes, documented controls, all-source intelligence, and publicly available information related to the supplier or contractor. Organizations can use open-source information to monitor for indications of stolen information, poor development and quality control practices, information spillage, or counterfeits. In some cases, it may be appropriate or required to share assessment and review results with other organizations in accordance with any applicable rules, policies, or inter-organizational agreements or contracts. Related Controls: SR-3, SR-5.

NIST SP 800-53 Rev 5 control SR-2 (Supply Chain Risk Management Plan) summarizes the requirements for this control: SR-2 · Supply Chain Risk Management Plan Control Statement: a. Develop a plan for managing supply chain risks associated with the research and development, design, manufacturing, acquisition, delivery, integration, operations and maintenance, and disposal of the following systems, system components or system services: [organization-defined parameter]; b. Review and update the supply chain risk management plan [organization-defined parameter] or as required, to

address threat, organizational or

NIST SP 800-53 Rev 5 control SR-6 (Supplier Assessments and Reviews) is assessed by examining, interviewing, and testing: SR-6 · Supplier Assessments and Reviews Control Statement: Assess and review the supply chain-related risks associated with suppliers or contractors and the system, system component, or system service they provide [organization-defined parameter]. Supplemental Guidance: Assess and review the supply chain-related risks associated with suppliers or contractors and the system, system component, or system service they provide [organization-defined parameter]. An assessment and review of supplier r